

# CONSTITUTION\_ADDENDUM \_QUALITY

## Constitution Addendum: Quality Stack (Principle I Exception)

**Revision: 1 Last modified: 2026-06-06T00:00:00Z**

### Principle I — Container-First

| Every service runs in a container. No exceptions.

The quality stack (`docker-compose.quality.yml`) is an **opt-in additive compose file**, not part of the mandatory two-container product topology. It is governed by Principle I but does not alter the product's runtime contract.

### Justification

#### Why This Is an Exception

The main `docker-compose.yml` defines exactly two containers (`qbittorrent`, `qbittorrent-proxy`) with `network_mode: host`. Adding SonarQube, PostgreSQL, and scanner containers to that file would:

1. Violate the product's minimal runtime topology
2. Require resources (2 GB+ RAM for SonarQube) that development machines may not have
3. Conflate CI/quality tooling with production services

## Why It Complies with Principle I

All quality services **are** containerized. The additive compose pattern (-f docker-compose.yml -f docker-compose.quality.yml) preserves the base topology while allowing on-demand quality infrastructure. No quality service is installed on bare metal.

## Trade-offs Accepted

| Concern                                                 | Mitigation                                                                 |
|---------------------------------------------------------|----------------------------------------------------------------------------|
| SonarQube PostgreSQL credentials default to sonar/sonar | Quality stack never exposed externally; bound to 127.0.0.1                 |
| Scanner containers use host network                     | Matches project convention; scanners are run-to-completion, not long-lived |
| Additional compose file increases surface area          | Profiles (run-once, quality) keep services off by default                  |

## Services Covered

- **sonarqube**: Code quality platform (community edition)
- **sonar-db**: PostgreSQL 16 for SonarQube persistence
- **snyk**: Dependency vulnerability scanner (requires SNYK\_TOKEN)
- **semgrep**: Static analysis with SARIF output
- **trivy**: Filesystem vulnerability and misconfiguration scanner
- **gitleaks**: Secret detection in git history

## Activation

```
$COMPOSE_CMD -f docker-compose.yml -f docker-compose.quality.yml  
               up -d sonarqube  
./scripts/scan.sh --all
```

## Decision Record

- **Date**: 2026-04-22
- **Decision**: Additive compose file for quality tooling, activated via profiles
- **Alternatives considered**: (1) Separate repo — rejected, splits codebase; (2) CI-only — rejected, developers need local access; (3) Bare-metal tools — rejected, violates Principle I

# Principles Compliance Check (Phase 10 Verification)

| Principle                  | Status           | Evidence                                                                                              |
|----------------------------|------------------|-------------------------------------------------------------------------------------------------------|
| I — Container-First        | <b>Compliant</b> | All quality services containerized in additive compose; product topology unchanged (2 containers)     |
| II — Manual CI             | <b>Compliant</b> | <code>./ci.sh</code> remains the canonical CI entry point; GitHub Actions workflows are supplementary |
| III — No secrets in repo   | <b>Compliant</b> | <code>.env</code> gitignored; CredentialScrubber filter active; Gitleaks scanner configured           |
| IV — WebUI credentials     | <b>Compliant</b> | <code>admin/admin</code> hardcoded and unchanged                                                      |
| V — Freeleech-only testing | <b>Compliant</b> | IPTorrents tests use <code>[free]</code> tagged results only                                          |
| VI — TDD                   | <b>Compliant</b> | 1,118 unit tests passing; coverage gate at 49%                                                        |

**Last verified:** 2026-04-22 (Phase 10 final verification)